CHECKLIST DE CÓDIGO SEGURO - OWASP TOP 10 2021

1. PÉRDIDA DE CONTROL DE ACCESO (A01:2021)

CHECKLIST DE IMPLEMENTACIÓN

Control	Implementación Web	Implementación Móvil	Código de Ejemplo
Verificación de permisos en cada endpoint	Middleware de autorización	Interceptors en API calls	app.get('/admin', authorize(['ADMIN']), controller)
Validación de propiedad de recursos	Check ownership en DB	Validar user_id en requests	if (resource.user_id !== req.user.id) return 403
Control de acceso basado en roles (RBAC)	Matriz de permisos	Roles en token JWT	roles: {admin: 3, user: 1}
Prevención de IDOR	UUIDs no secuenciales	Validación de recursos	validateUserOwnsResource(resourceId, userId)
Rate limiting por usuario	Redis counters	Throttling en cliente	limiter({ windowMs: 900000, max: 10 })

2. FALLAS CRIPTOGRÁFICAS (A02:2021)

CHECKLIST DE IMPLEMENTACIÓN

Control	Implementación	Herramientas	Configuración
Algoritmos fuertes	Argon2id, bcrypt	libsodium, bcryptjs	{ algorithm: 'argon2id', time: 3, memory: 65536 }
TLS 1.3 obligatorio	HSTS headers	nginx config	ssl_protocols TLSv1.3;
Gestión segura de secrets	Vault, AWS Secrets	dotenv-vault	vault read secret/data/app

Control	Implementación	Herramientas	Configuración
Cifrado en reposo	AES-256-GCM	crypto module	crypto.createCipheriv('aes-256-gcm', key, iv)
Rotación de claves	Key rotation schedule	KMS automated	kms.rotateKey()

3. INYECCIÓN DE CÓDIGO (A03:2021)

CHECKLIST DE IMPLEMENTACIÓN

Tipo	Prevención	Librerías	Ejemplo
SQL Injection	Prepared statements	Sequelize, TypeORM	User.find({ where: { id: param } })
NoSQL Injection	Sanitización de queries	mongoose-sanitize	sanitizeFilter(req.query)
Command Injection	Validación de input	validator.js	validator.isAlphanumeric(input)
XSS	Escaping output	DOMPurify, helmet	DOMPurify.sanitize(html)
LDAP Injection	Escape DN characters	ldap-escape	escape.dn(input)

4. DISEÑO INSEGURO (A04:2021)

CHECKLIST DE IMPLEMENTACIÓN

Principio	Implementación	Técnicas	Verificación
Threat Modeling	Diagramas de seguridad	STRIDE, DREAD	Análisis de flujos de datos

Principio	Implementación	Técnicas	Verificación
Principio de menor privilegio	Permisos mínimos	RBAC granular	Auditoría de permisos
Defensa en profundidad	Múltiples capas	WAF, validación, cifrado	Security layers check
Fail Secure	Default deny	Error handling seguro	Pruebas de fallos
Separation of Duties	Múltiples aprobaciones	Workflows de aprobación	Validación de procesos

5. CONFIGURACIÓN DE SEGURIDAD INCORRECTA (A05:2021)

CHECKLIST DE IMPLEMENTACIÓN

Área	Configuración Segura	Herramientas	Verificación
Entornos	Separación clara	dotenv, config	NODE_ENV=production
Headers de seguridad	Helmet.js	security headers	X-Frame-Options: DENY
CORS	Orígenes específicos	cors package	origin: ['https://mydomain.com']
Servidores	Hardening OS	ansible, docker	security.scan()
Logs	Sin información sensible	pino, winston	redact: ['password', 'token']

6. COMPONENTES VULNERABLES (A06:2021)

CHECKLIST DE IMPLEMENTACIÓN

Control	Implementación	Herramientas	Automatización
Inventario de dependencias	package.json audit	npm audit, yarn audit	npm audit --audit-level=high
SCA continuo	GitHub Dependabot	Snyk, WhiteSource	CI/CD integration
Parcheo automático	Auto-update pipelines	renovate bot	renovate.json
Verificación de checksums	Integrity checks	npm ci --audit	hash verification
Dependencies mínimas	Tree shaking	webpack bundle analyzer	bundle-size-check

7. FALLAS DE IDENTIFICACIÓN Y AUTENTICACIÓN (A07:2021)

CHECKLIST DE IMPLEMENTACIÓN

Control	Implementación	Estándar	Ejemplo
MFA obligatorio	TOTP, WebAuthn	RFC 6238	speakeasy.generateSecret()
Protección contra fuerza bruta	Rate limiting	OWASP ASVS	express-rate-limit
Gestión segura de sesiones	JWT con rotación	RFC 7519	jwt.sign(payload, secret, {expiresIn: '15m'})
Password policies	NIST 800-63B	zxcvbn	passwordStrength(value)

Control	Implementación	Estándar	Ejemplo
Logout seguro	Server-side invalidation	Session destruction	session.destroy()

8. FALLAS DE INTEGRIDAD DE DATOS (A08:2021)

CHECKLIST DE IMPLEMENTACIÓN

Control	Implementación	Tecnología	Verificación
Validación de integridad	Checksums, hashes	SHA-256	crypto.createHash('sha256')
Firmas digitales	JWS, código de verificación	jsonwebtoken	jwt.verify(token, publicKey)
Protección de serialización	Validación de objetos	class-transformer	plainToClass(User, data)
Verificación de dependencias	Lock files, hashes	npm ci, yarn	package-lock.json
CI/CD seguro	Signing de commits	GPG, commit signing	git commit -S

9. FALLAS EN REGISTRO Y MONITOREO (A09:2021)

CHECKLIST DE IMPLEMENTACIÓN

Control	Implementación	Herramientas	Configuración
Logging estructurado	JSON format	Winston, Pino	{ level: 'info', timestamp: true }
Alertas de seguridad	SIEM integration	Splunk, ELK	alerts: { failedLogins: 5 }

Control	Implementación	Herramientas	Configuración
Retención de logs	Policy de retención	Log rotation	retention: '30d'
Monitoreo en tiempo real	Dashboard seguridad	Grafana, CloudWatch	realTimeAlerts: true
Auditoría de eventos	Trazabilidad completa	Audit logs	who, what, when, where

10. FALSIFICACIÓN DE SOLICITUDES (SSRF) (A10:2021)

CHECKLIST DE IMPLEMENTACIÓN

Control	Implementación	Técnica	Ejemplo
Validación de URLs	Lista blanca de dominios	DNS resolution	dns.lookup(hostname)
Restricción de esquemas	Solo HTTP/HTTPS	URL parsing	url.protocol === 'https:'
Timeouts y límites	Tiempos de respuesta	axios config	timeout: 5000
Sandboxing	Entornos aislados	VM, containers	docker run --network=none
Seguridad en red	Firewall, VLANs	Network policies	iptables -A OUTPUT